

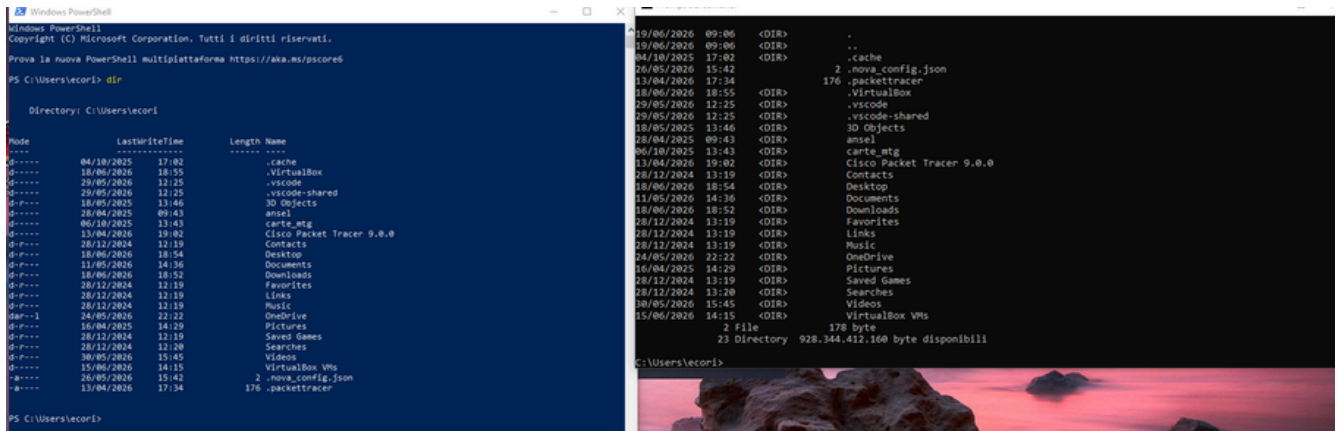
S11L5

**PROGETTO
S11L5**

TANCREDI
DE SIMONE

1 Powershell

Inizio aprendo Powershell e il prompt dei comandi, ho avviato il comando **dir**



```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Prova la nuova PowerShell multiplatforma https://aka.ms/powershell

PS C:\Users\ecori> dir

Directory: C:\Users\ecori

Mode                LastWriteTime         Length Name
----                -
d----- 04/10/2025 17:02             .cache
d----- 18/05/2026 18:35             .VirtualBox
d----- 29/05/2026 12:25             .vscode
d----- 18/05/2025 13:46             .vscode-shared
d----- 28/04/2025 09:43             .ansel
d----- 18/05/2026 13:43             .certs_mtg
d----- 13/04/2026 19:02             .Cisco Packet Tracer 9.0.0
d----- 28/12/2024 12:19             .Contacts
d----- 18/05/2026 18:34             .Desktop
d----- 11/05/2026 14:36             .Documents
d----- 18/05/2026 18:52             .Downloads
d----- 28/12/2024 12:19             .Favorites
d----- 28/12/2024 12:19             .Links
d----- 28/12/2024 12:19             .Music
d----- 24/05/2026 22:22             .OneDrive
d----- 16/04/2025 14:29             .Pictures
d----- 28/12/2024 12:19             .Saved Games
d----- 28/12/2024 12:19             .Searches
d----- 30/05/2026 15:45             .Videos
d----- 15/06/2026 14:15             .VirtualBox VMs
d----- 26/05/2026 15:42             .nova_config.json
d----- 13/04/2026 17:34             .176 .packettracer

PS C:\Users\ecori>
```

```
19/06/2026 09:06 <DIR> .
19/06/2026 09:06 <DIR> ..
04/10/2025 17:02 <DIR> .cache
26/05/2026 15:42 2 .nova_config.json
13/04/2026 17:34 176 .packettracer
18/06/2026 18:55 .VirtualBox
29/05/2026 12:25 <DIR> .vscode
29/05/2026 12:25 <DIR> .vscode-shared
18/05/2025 13:46 <DIR> .3D Objects
28/04/2025 09:43 <DIR> .ansel
06/10/2025 13:43 <DIR> .certs_mtg
13/04/2026 19:02 <DIR> .Cisco Packet Tracer 9.0.0
28/12/2024 12:19 <DIR> .Contacts
18/06/2026 18:54 <DIR> .Desktop
11/05/2026 14:36 <DIR> .Documents
18/06/2026 18:52 <DIR> .Downloads
28/12/2024 12:19 <DIR> .Favorites
28/12/2024 12:19 <DIR> .Links
28/12/2024 12:19 <DIR> .Music
24/05/2026 22:22 <DIR> .OneDrive
16/04/2025 14:29 <DIR> .Pictures
28/12/2024 12:19 <DIR> .Saved Games
28/12/2024 12:19 <DIR> .Searches
30/05/2026 15:45 <DIR> .Videos
15/06/2026 14:15 <DIR> .VirtualBox VMs
15/06/2026 14:15 <DIR> .VirtualBox VMs
2 file 178 byte
23 Directory 928.344.412.160 byte disponibili

C:\Users\ecori>
```

Quali sono gli output del comando dir?

Il comando **dir** stampa la directory corrente facendoti vedere i file e le directory che ci sono dentro. Nella colonna mode in powershell possiamo anche visualizzare le proprietà della cartella o del file.

Quali sono i risultati?



```
PS C:\Users\ecori> ping 8.8.8.8

Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=14ms TTL=115
Risposta da 8.8.8.8: byte=32 durata=14ms TTL=115
Risposta da 8.8.8.8: byte=32 durata=14ms TTL=115

Statistiche Ping per 8.8.8.8:
Pacchetti: Trasmessi = 3, Ricevuti = 3,
Persi = 0 (0% persi),
Tempo approssimativo percorsi andata/ritorno in millisecondi:
Minimo = 14ms, Massimo = 14ms, Medio = 14ms
Controllo C
PS C:\Users\ecori>
```

```
Risposta da 8.8.8.8: byte=32 durata=14ms TTL=115

Statistiche Ping per 8.8.8.8:
Pacchetti: Trasmessi = 3, Ricevuti = 3,
Persi = 0 (0% persi),
Tempo approssimativo percorsi andata/ritorno in millisecondi:
Minimo = 14ms, Massimo = 14ms, Medio = 14ms
Controllo C
PS C:\Users\ecori>
```

Nel caso di **ping** il comando funziona ugualmente su entrambi, anche nel caso di **cd**.

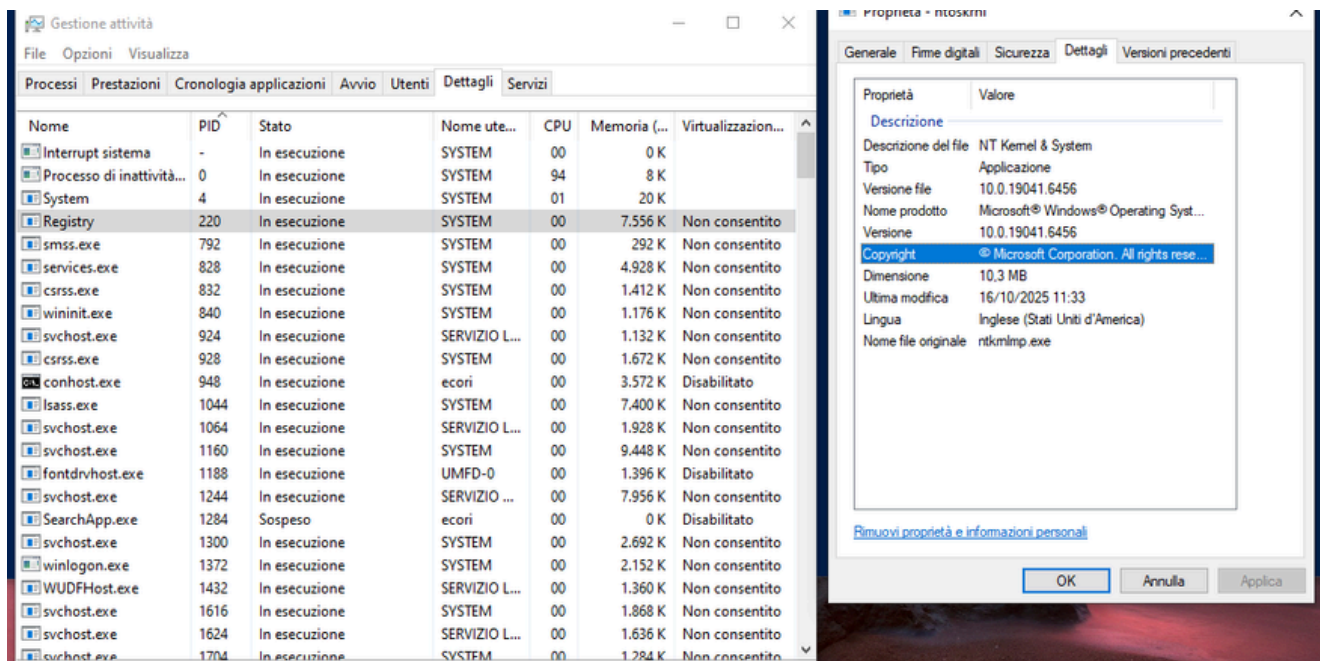
Qual è il comando PowerShell per dir?

In **Powershell** alcuni comandi come **ping** e **cd** sono mantenuti come alias per non costringere l'utente a imparare i comandi nativi della shell da 0. Il vero nome del comando dir è **Get-ChildItem**

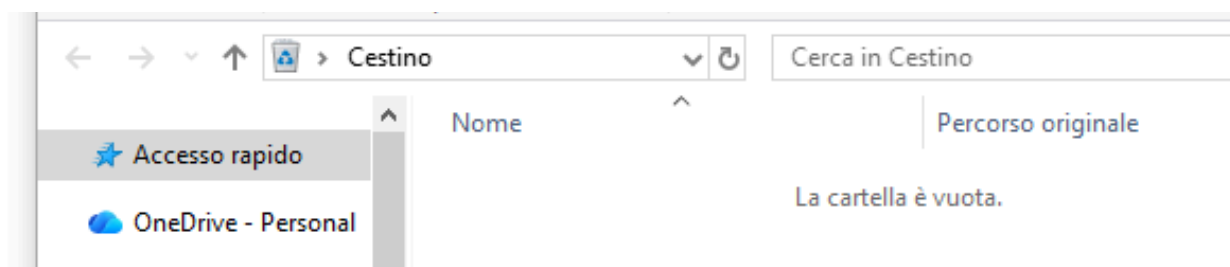
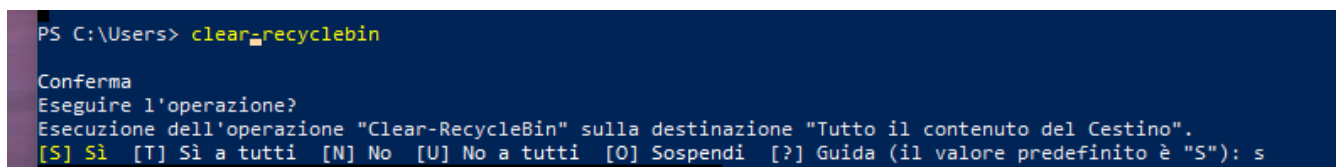
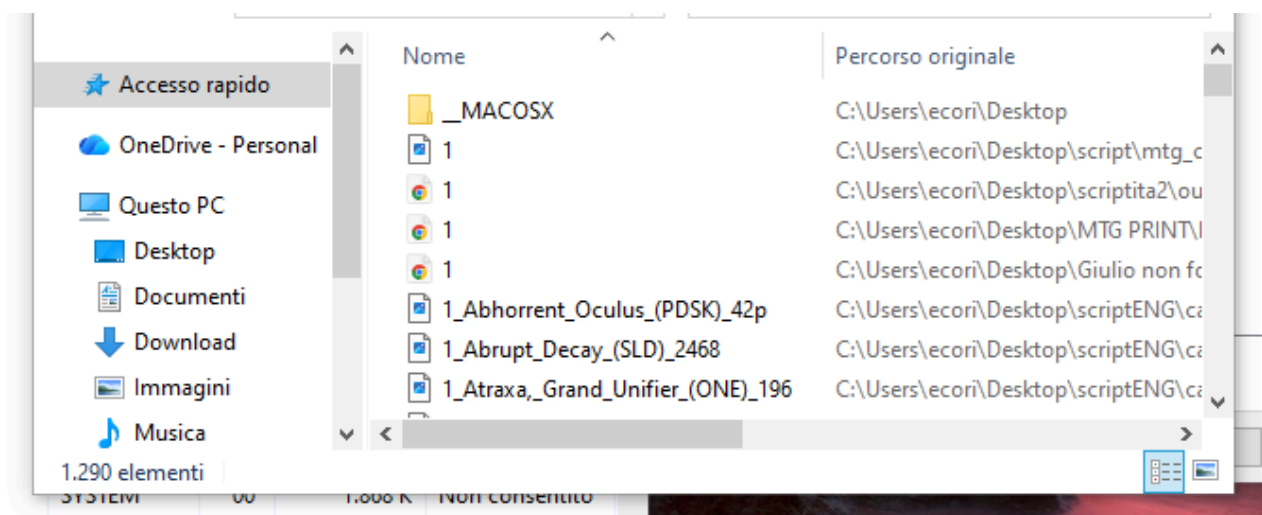
Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Da dettagli posso ottenere l'**id del processo**, lo **stato** del processo il **nome utente** che ha avviato il processo il **consumo** a livello di CPU e memoria e **se la virtualizzazione è consentita o meno**.

Dalle proprietà le informazioni sono svariate, come la data creazione, l'ultimo accesso, il tipo di file, la descrizione, le firme digitali, alcune informazioni riguardanti la sicurezza e le autorizzazioni a livello utente. Inoltre ho una descrizione completa del file come mostrato nello screenshot.



Ora svuoterò il cestino con Powershell inserendo il comando **clear-recyclebin**.



Cosa è successo ai file nel cestino?

Sono stati eliminati.

Ricerca alcuni comandi che potrebbero essere utili ad un analista di sicurezza e registra le tue scoperte

- **Get-Process**

Consente di elencare tutti i processi attivi sul sistema. Utile per trovare dei processi sospetti.

- **Get-NetTCPConnection**

È la versione PowerShell avanzata del classico comando netstat. Mostra tutte le connessioni di rete attive e le porte in ascolto. Se un attaccante si sta connettendo alla rete questo comando ci mostrerà il suo indirizzo ip da lì se ci sono dei processi in esecuzione che stanno esfoliando dei dati, tramite poi il PID possiamo risalire al processo che sta eseguendo questa operazione.

- **Get-CimInstance Win32_StartupCommand**

Ispeziona i programmi configurati per avviarsi automaticamente ad ogni accensione del computer. Verifica se c'è la persistenza di processi malevoli nel sistema che si avviano all'accensione della macchina.

- **Get-WinEvent**

Permette di interrogare i registri di Windows in modo rapido tramite query e filtri, con questo comando possiamo analizzare i log e trovare anomalie.

- **Get-FileHash**

Calcola l'impronta digitale, hash SHA-256 o MD5, di un file specifico per poterne verificare l'integrità.

2 Studio loc

Dal link anyrun possiamo dedurre che si tratta di un malware scaricato da un link github compromesso. Il malware è protetto da un'offuscatore ed esegue un tentativo di Process Injection. Vediamo nel dettaglio il processo di infezione.

Processo di infezione

Il primo passo è il vettore iniziale **Firefox** che visita un link malevolo **Github**, successivamente viene eseguito il primo payload **Jvczfhe.exe** questo file viene scaricato ed eseguito sul sistema

Successivamente il processo di prima genera un processo figlio **cmd.exe /c timeout 21 & exit**, in pratica aspetta 21 secondi prima di eseguirsi cercando di evadere l'analisi della sandbox. Finita l'attesa si avvia il processo **Muadnrd.exe** che genera un'altra attesa, questo è il payload che è contrassegnato come malware.



Il malware poi probabilmente si accorge di essere in una sandbox, lo capiamo dal gestore errori di Windows **Werfault.exe** che punta ai due processi malevoli **Jvczfhe.exe** e **Muadnrd.exe**

L'offuscazione è stata eseguita con **.NET reactor** che è un offuscatore commerciale e lo possiamo notare da:



Cliccando nel processo malevolo possiamo avere più informazioni.

Analisi del traffico di rete

Guardando le richieste **HTTP** e i **log TCP** I primi pacchetti **GET** sono diretti verso i server **Microsoft/GitHub** per scaricare l'eseguibile.

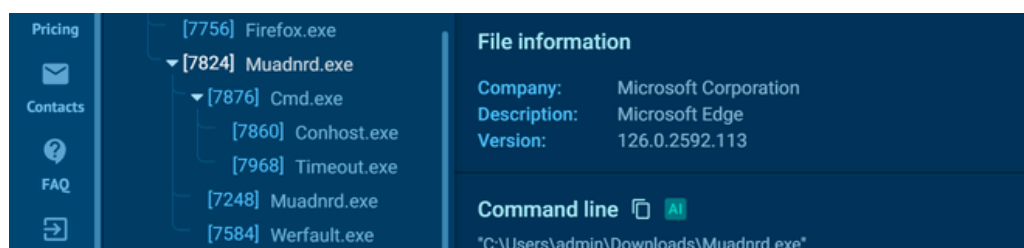
Subito dopo l'esecuzione, Firefox invia diverse richieste **POST** verso IP localizzati sia negli Stati Uniti che in Germania. Sebbene a generarle sia apparentemente Firefox, in un contesto reale potrebbe trattarsi di traffico **C2** o di esfiltrazione dati nascosta dietro traffico web standard.

Analisi di anyrun

Per confermare i miei sospetti controllo anche l'analisi di anyrun.



Da **62**, ma si tratta di un malware a tutti gli effetti. Possiamo notare che anche se è crashato il processo poi ne ha avviato uno identico. lo capiamo da **Executes application when crashes**. Notiamo anche la fase di ricognizione del malware che controlla le impostazioni di sicurezza di Windows lo capiamo da **Check Windows Trust Settings** e **Reads security settings of Internet Explorer**. Ne possiamo dedurre che il Malware sta tentando di mascherarsi come un processo di **Microsoft Edge**, possiamo capirlo bene guardando le informazioni del file:



Tuttavia la firma digitale del processo non ha ingannato il sistema, lo possiamo notare da **Code signing: Untrusted**, in questo caso l'ambiente Sandbox anyrun non si è fidato.

Analisi finale

Ora abbiamo tutte le informazioni necessarie per dire che con altissima probabilità si tratta di un **malware** che mira al **furto di dati**, un **loader**. Il malware viene eseguito mascherandosi da **microsoft edge** ed esegue richieste **POST** verso IP stranieri, probabilmente per mandare i dati all'attaccante.

3 Esplorazioni di Nmap

Controllo per prima cosa il manuale di **nmap**

```
NMAP(1)                                Nmap Reference Guide                                NMAP(1)

NAME
    nmap - Network exploration tool and security / port scanner

SYNOPSIS
    nmap [Scan Type...] [Options] {target specification}

DESCRIPTION
    Nmap ("Network Mapper") is an open source tool for network exploration
    and security auditing. It was designed to rapidly scan large networks,
    although it works fine against single hosts. Nmap uses raw IP packets in
    novel ways to determine what hosts are available on the network, what
    services (application name and version) those hosts are offering, what
    operating systems (and OS versions) they are running, what type of
    packet filters/firewalls are in use, and dozens of other
    characteristics. While Nmap is commonly used for security audits, many
    systems and network administrators find it useful for routine tasks such
    as network inventory, managing service upgrade schedules, and monitoring
    host or service uptime.

    The output from Nmap is a list of scanned targets, with supplemental
    information on each depending on the options used. Key among that
    information is the "interesting ports table". That table lists the port
    number and protocol, service name, and state. The state is either open,
    filtered, closed, or unfiltered. Open means that an application on the
    target machine is listening for connections/packets on that port.
    Filtered means that a firewall, filter, or other network obstacle is
    blocking the port so that Nmap cannot tell whether it is open or closed.
    Closed ports have no application listening on them, though they could
    open up at any time. Ports are classified as unfiltered when they are
    responsive to Nmap's probes, but Nmap cannot determine whether they are
    open or closed. Nmap reports the state combinations open|filtered and
    closed|filtered when it cannot determine which of the two states
    describe a port. The port table may also include software version
    details when version detection has been requested. When an IP protocol
    scan is requested (-sO), Nmap provides information on supported IP
    protocols rather than listening ports.

Manual page nmap(1) line 1 (press h for help or q to quit)
```

Cos'è nmap e per cosa viene usato?

E' uno strumento che ci permette di scansionare le **porte, servizi, e le loro versioni**, nonché **gli host** su una determinata rete. E' fondamentale nella cybersecurity, spesso le porte e i servizi sono degli ottimi **vettori di attacco** e avere le informazioni necessarie come porte, servizi e le loro versioni è la base sia per un attaccante che un difensore.

Quale comando viene usato nell'esempio 1 e quali sono le opzioni?

Navigando nel manuale il primo esempio è **nmap -A -T4 scanme.nmap.org** -A sta per **aggressive scan** sto dicendo a nmap di usare 4 comandi contemporaneamente per conoscere

Sistema operativo, versione dei servizi, eseguire una scansione con **script NSE**, che usa degli script nmap per trovare **vulnerabilità note**, e un **traceroute** che traccia il percorso dei pacchetti di rete, per mostrarmi quali e quanti router o salti ci sono tra la me e la macchina scansionata. i comandi sono rispettivamente **-O, -sV, -sC, --traceroute**.

T4 invece controlla la velocità e l'aggressività temporale dello scan.

Scansione localhost, quali porte e servizi sono aperti?

Porte aperte **21** e **22** con servizi **ssh** e **ftp**.

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 07:25 -0400
Failed to resolve "-A".
Failed to resolve "-T4".
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00011s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
```

Scansione della mia rete, a quale rete appartiene la tua VM?

Usando il comando **ip address** vedo che la mia VM appartiene alla rete **10.0.2.15** subnet mask **24, 255.255.255.0**

```
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 85449sec preferred_lft 85449sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86367sec preferred_lft 14367sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
3: ovs-system: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 12:48:ec:26:c9:9e brd ff:ff:ff:ff:ff:ff
4: s1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 72:70:2e:d4:ad:48 brd ff:ff:ff:ff:ff:ff
```

Ora scansiono la mia rete con **nmap -A T4 10.0.2.0/24**

Quanti host sono attivi?

Uno soltanto con il **10.0.2.15** e servizi **ftp** e **ssh** su porta **21** e **22**

Qual è lo scopo di scanme.nmap.org?

Lo scopo del sito è di fare prove con nmap per vedere se è installato correttamente e per imparare ad utilizzare nmap per fare test etc.

Hello, and welcome to Scanme.Nmap.Org, a service provided by the [Nmap Security Scanner Project](#).

We set up this machine to help folks learn about Nmap and also to test and make sure that their Nmap installation (or Internet connection) is working properly. You are authorized to scan this machine with Nmap or other port scanners. Try not to hammer on the server too hard. A few scans in a day is fine, but don't scan 100 times a day or use this site to test your ssh brute-force password cracking tool.

Thanks
-Fyodor

Quali porte e servizi sono aperti? Quali porte e servizi sono filtrati? Qual è l'indirizzo IP del server? Qual è il sistema operativo?

Eseguendo uno scan aggressivo possiamo ottenere tutte queste informazioni.

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 07:37 -0400
Failed to resolve "-A".
Failed to resolve "-T4".
Stats: 0:03:12 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 41.20% done; ETC: 07:45 (0:04:28 remaining)

[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 07:41 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-favicon: Nmap Project
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 487.17 seconds
```

Porte e servizi aperti:

22 tcp servizio ssh
80 tcp servizio HTTP
9929 tcp servizio nping-echo Nping echo
31337 tcp servizio tcpwrapped

Ci sono 966 porte filtrate.

Indirizzo ip server: 45.33.32.156

Sistema operativo: Linux

Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Nmap può essere utilizzato in modo **malevolo** per trovare **porte** e **servizi** aperti che possono costituire dei **vettori di attacco**. Può inoltre fare ricognizione sulla rete per trovare **host connessi**.

Possiamo poi risparmiare tempo dell'attacco trovando il **sistema operativo target** e la sua versione per utilizzare **exploit** progettati e studiati proprio per i suddetti.

Si possono inoltre utilizzare le **funzioni avanzate** di Nmap per frammentare i pacchetti di rete, falsificare gli indirizzi IP di provenienza, o rallentare appositamente lo scan con funzioni **stealth** per non farsi rilevare dai sistemi di difesa **IDS** o **IPS** della vittima.

A livello **difensivo** possiamo utilizzarlo per vedere gli **host connessi** e identificare potenziali dispositivi sulla rete che non dovrebbero essere li'. Possiamo inoltre identificare se ci sono servizi e porte **vulnerabili** che dovrebbero essere chiuse o filtrate dal **firewall**.

Possiamo poi identificare servizi che andrebbero aggiornati con il comando **-sV**, service version, e controllare se sono alla versione più sicura.

Ultima cosa possiamo utilizzarlo per un **vulnerability assesment iniziale**, con gli script automatici di nmap possiamo identificare **falle critiche e note**.